

SEE ALSO Newsletter of January 31, 2025

[doc. web no. 10097012]

Provision of November 27, 2024

Register of provisions

no. 736 of November 27, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by

Prof. Pasquale Stanzione, president, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Counsel Fabio Mattei, secretary general;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament

and of the Council, of April 27, 2016, concerning

the protection of natural persons with regard to

the processing of personal data, as well as the free

movement of such data and repealing Directive

95/46/EC (General Data Protection Regulation, hereinafter "Regulation");

HAVING REGARD to the Code on the protection of personal data

(legislative decree of June 30, 2003, no. 196), as

amended by legislative decree of August 10, 2018, no. 101, containing

provisions for the adaptation of the national

legislation to the aforementioned Regulation (hereinafter

"Code");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the secretary

general pursuant to Article 15 of the Guarantor's regulation no. 1/2000, adopted by resolution of June 28, 2000;

REPORTING Attorney Guido Scorza;

1. THE INSTRUCTIONAL ACTIVITY CARRIED OUT

1.1. Premise

By act of August 13, 2024, no. 98907 (notified on

the same date via certified email), which is to be understood as fully referenced and reproduced herein, the Office initiated, pursuant to Article

166, paragraph 5, of the Code, a procedure for

the adoption of the measures referred to in Article 58, paragraph

2, of the Regulation against E.ON Energia

S.p.A. (hereinafter "E.ON" or "Company" or also

"Data Controller"), represented by the legal representative

pro tempore, with registered office in Milan (MI), Via

dell'Unione no. 1, VAT no. 03429130234.

The procedure originates from an investigation

initiated by the Authority, following the receipt of

two separate complaints lodged against E.ON. More specifically, with complaint no. 352614

the complainant reported receiving

unwanted calls made on behalf of the Company

and the lack of response to the request to exercise

the rights under Articles 15 et seq. of the Regulation.

With complaint no. 367993 the complainant indicated the

receipt of numerous promotional calls from

E.ON made in conjunction with the activation of

two energy supplies and that, by the Company's own admission, during the loading of the agreement into the corporate systems, the consents granted under

the personal data protection legislation

had been processed differently than what was stated in the contract.

1.2. The requests for information made by the Authority

1.2.1. The request for information regarding complaint no. 352614

By complaint act of March 13, 2024 (see prot. no. 31258), the complainant lamented the lack of response from E.ON to a request to exercise the rights under Articles 15 et seq. of Reg. EU no. 2016/679 submitted on January 22, 2024. The request followed the receipt of a promotional call made in the name and on behalf of the aforementioned Company, during which the complainant became aware that E.ON was in possession of her personal and contact data, including the institutional email address. During the telephone conversation, the operator stated that the contact had been requested by the complainant herself through participation in an advertising campaign conducted via Facebook; however, the complainant highlighted that she had never activated any account on the aforementioned social platform. After examining the complaint and all the documentation attached thereto, by note of March 29, 2024 (see Prot. no. 39774), the Office notified the Company of a request for information pursuant to Article 157 of the Code, inviting E.ON to provide its observations regarding what was represented therein and to communicate whether it intended to comply with the complainant's requests.

Subsequently, noting that due to a mere material error the communication had not reached the Company's address, by note of May 27, 2024 (see Prot. no. 64326) the Office reiterated the request.

Thus, in response dated June 14, 2024 (see Prot. no. 73277 of June 17, 2024), E.ON preliminarily stated that "The request to exercise the rights regarding personal data protection by the Complainant followed a telephone contact by her with E.ON staff who, already on January 18, 2024, offered her some information regarding the activities of personal data processing carried out by E.ON: more specifically, during this telephone conversation the Complainant was informed that her personal data had been collected following a Facebook campaign that concluded with the possibility of filling out an online form to express interest in the products and services offered by the Company and to request a telephone contact with E.ON staff for further information on the same."

On this point, the Company also highlighted that "based on agreements regarding the conditions for advertisements to acquire new customers on the Facebook platform, E.ON launched the advertising campaign 'ClimaSmart Air Conditioner' for the promotion of its products and services. The campaign

****1.2.1. The optional compilation of an online form****

provided for on the Facebook platform where personal data (first name, last name, email, and phone number) could be entered and consent could be given or denied. The personal data of the Claimant were transmitted to the company's CRM via API and then processed by E.ON staff, with the purpose of contacting the interested party again.

In light of the aforementioned observations, in the opinion of the Company, the Claimant's data had likely been entered into the form in question by a third party and without the authorization of the interested party.

Regarding the lack of response to the request to exercise the rights referred to in Articles 15 et seq. of the Regulation submitted by the Claimant, E.ON noted that this omission was caused by a human error made by the supplier XX, which the Company uses for "the digitization of certain processes, and, in general, for the scanning of registered letters that are subsequently indexed and transmitted to the relevant company functions. In this case, the management flow of paper mail did not operate correctly, resulting in the failure to upload the digitized document with the Claimant's request."

With reference to the more general management of requests to exercise rights, the Company highlighted that it had made available to interested parties "a series of dedicated channels to facilitate the exercise of privacy rights, as also indicated in the privacy notice published on the website, in section 11 Methods of exercising rights

(<https://www.eon-energia.com/informazioni-utili/informativa-pri-vacy.html>)," that it had implemented specific internal procedures for managing requests, as well as organizing "periodic training sessions, both in-person and with digital platforms, for employees and the sales network, customizing the content and always placing great importance on the correct management of personal data."

Finally, in the same note dated June 14, 2024, the data controller responded to the Claimant's requests to exercise her rights. The Claimant did not take advantage of the opportunity to submit further observations and/or requests.

****1.2.2. The request for information regarding complaint no. 367993****

With a complaint dated May 2, 2024 (see Prot. no. 53146), the interested party stated that she had signed two contracts for the supply of electricity and gas with E.ON Energia in November 2023. The Claimant complained that starting from November 22, 2023, she had been the recipient of a multitude of unwanted promotional phone calls from "various companies that intend to offer her various services and products." Considering that the calls had begun precisely at the same time as the activation of the supplies by E.ON, the interested party attributed these contacts to an unlawful transfer of her personal data to third parties carried out by the Company.

Thus, on February 29, 2024, the Claimant contacted the data controller to obtain documentary evidence of the consents given regarding the processing of her personal data.

From the documentation transmitted by the Claimant, it emerged that E.ON had responded to the requester on March 27, 2024, stating that "during the implementation of the contracts in question in our systems, the privacy consents were recorded, due to a mere material error, in a manner inconsistent with the authorizations you provided at the time of signing." On the same occasion, the Company reassured the Claimant, stating that it had registered the denial in its systems.

Nevertheless, the interested party continued to receive multiple promotional contacts; therefore, on April 7, 2024, she contacted the data controller again, asking to "promptly activate measures so that those to whom you have provided my personal data do not dare to call me anymore," but the Company did not provide any response.

In the complaint, the interested party also stated that the receipt of numerous unwanted phone calls was causing a series of inconveniences to her personal and professional life, also due to the public office she held in the past (see "(...) she confesses to feeling very uncomfortable and ethically conflicted about deciding whether or not to answer these cell phone numbers: indeed, they could be ordinary Citizens who genuinely want to engage with her. For these reasons, she often calls back the same numbers to ascertain that they do not actually belong to them" and further "Please take into account that the facts narrated have significantly lowered the quality of life of the complainant, causing her considerable physical and psychological stress. Among other things, the calls also come at times

of rest, such as in the early afternoon hours").

Thus, after examining all the circumstances presented and attached to the complaint, in a note dated May 27, 2024 (see Prot. no. 64362), the Office notified the Company of a request for information pursuant to Article 157 of the Code, inviting E.ON to provide its observations regarding what was represented therein and to communicate whether it intended to comply with the requests of the Claimant.

Subsequently, in a response dated June 14, 2024 (see Prot. no. 73269 of June 17, 2024), the Company stated that following the receipt of the requests transmitted by the Claimant between late February 2024 and early April 2024, "the E.ON Customer Service accessed the Company's IT systems and verified that, due to a mere material error, during the transcription of the Claimant's data into the system...

****CRM Management of E.ON****

The consents granted by the Claimant had been reversed compared to those provided during the activation phase of the services, resulting in a consent recorded in the systems for the transfer of data to E.ON's commercial partners and not the consent for the customization of offers provided during the activation phase of the services. The Customer Service then proceeded immediately to correct and update the Claimant's privacy preferences and to communicate this to the Claimant, reiterating that the personal data in question had not been shared with partners or third parties for their marketing or co-marketing purposes.

The Company also specified that it had contacted the Claimant on November 8, 2023, in order to formalize the service supply contracts and had attempted further contact (so-called "caring call") after the issuance of invoices for the services provided, when the systems of E.ON still showed the "consent for the sending of communications regarding initiatives, commercial offers, questionnaires, surveys, and market research through ordinary letters and/or telephone calls, emails, SMS, MMS, notifications, and newsletters" as active.

Regarding the contacts useful for exercising rights, E.ON highlighted that "(...) the privacy notice is available in the 'Privacy and Governance' section in the footer of the Site (<https://www.eon-energia.com/>). The notice has a section specifically dedicated to the 'Methods of exercising rights,' in which the various channels established to facilitate the exercise of rights by data subjects are reported (...)"

Finally, with reference to the measures adopted concerning telemarketing activities towards so-called prospects, E.ON stated that "the Database of the supplier on which the Company relies is filtered by removing customers already present in E.ON's customer base. Every 15 days, a 'prospect' list is created for each teleseller. Before sending, all lists are cross-checked with the public opposition register to remove from the lists customers who are registered there. Following the outcome of the verification, the list of contactable subjects (therefore not present in the Company's customer base and not registered in the opposition register) is sent via the system called SafeFileTransferProtocol (sftp), one dedicated for each partner. In the following 15 days, contact attempts are made. After 15 days, the lists are again deposited in sftp to return them to the supplier."

Conversely, regarding customers already present in the customer base, E.ON noted that "periodically (usually once a month), a list of contacts chosen from customers who had provided consent for marketing activities is sent to the telesellers. Contact attempts are made within the following month. At the end of the month, customers are classified as non-contactable for a subsequent determined period of time."

The Claimant, finally, availing herself of the powers recognized by the legal system, with a note dated June 26, 2024 (ref. 78686 of June 27, 2024), reiterated the receipt of numerous promotional calls and highlighted that although she had had the same phone number for over twenty years, she had never before received so many promotional calls.

1.3. ****Consolidation of Proceedings****

Considering that the complaints in files no. 352614 and 367993 are directed against the same data controller and concern issues of the same nature, in order to promote a comprehensive examination and implement the principles of efficiency and speed as per Article 9 of internal regulation no. 1/2019 (available at www.gpdp.it, doc. web no. 9107633), it was deemed appropriate to jointly address the complaints pursuant to and for the effects of the subsequent Article 10 of the same regulation.

In this case, moreover, the joint treatment appeared more suitable to guarantee the right of defense and the need not to aggravate the procedure, also from the perspective of the lesser expenditure of time and resources that it entails for the data controller.

1.4. ****Allegation of Violations****

The Office, at the conclusion of the investigation, adopted the aforementioned act of contestation no. 98907/24 in which, first of all, it was observed that from the findings and the documentation overall acquired, there seemed to emerge a lack of awareness on the part of the Company regarding the obligations imposed on the data controller as established by the current legislation on personal data protection and, more specifically, by the principle of so-called accountability as per Articles 5, paragraph 2, and 24 of the Regulation.

The Company, in fact, in the context of the responses provided to the Authority's requests, had limited itself to attributing the behaviors subject to complaint to third parties or to errors committed by its collaborators and commercial partners, as if they could constitute an exemption from all liability, without fulfilling the burden of alleging and demonstrating that it had adopted all the measures prescribed by law to avoid incurring such violations.

Moreover, from the elements that emerged during the investigation, it seemed possible to attribute to E.ON the conduct of telemarketing and teleselling activities in the absence of an adequate legal basis and thus in violation of Articles 5, 6, and 7 of the Regulation and Article 130 of the Code.

With specific reference to the promotional activities carried out through social channels, in fact, it emerged that the Company had used the personal data of the Claimant without adopting adequate measures to verify their legitimate origin, nor...

the identity of the subjects who made the contribution.

Further critical aspects had also emerged regarding the processing of personal data of customers carried out for marketing purposes, with particular reference to the procedures for acquisition and management of the consents granted by the data subjects.

With reference to complaint no. 367993, E.ON had attributed the conduct subject to complaint to a mere human error occurring in the valuation of consents. However, this statement revealed a dual order of criticality. On one hand, in fact, such statements indicated the failure to implement appropriate measures to verify and ensure the correspondence between the consents granted by the data subjects and the information recorded in the company's systems, thus resulting in telemarketing activities being carried out without an appropriate legal basis.

On the other hand, what had occurred seemed to imply the failure to comply with the obligations set forth in Article 2 – fourteenth of the Code regarding the identification, training, direction, and monitoring of

the internal subjects within the data controller's organization who carry out personal data processing on behalf of the Company.

Furthermore, the statements provided regarding the lack of response to the request for the exercise of rights in file no. 352614, attributed to an error committed by a business partner, suggested a violation of the obligations imposed on the data controller pursuant to Article 28 of the Regulation (so-called culpa in eligendo and culpa in vigilando).

The Office, therefore, contested the following allegations of violation against E.ON:

- a) Articles 5, 6, 7, and 24 of the Regulation, as well as Article 130 of the Code, for having carried out personal data processing in violation of the principles of lawfulness and accountability, in the absence of an appropriate legal basis and implementing technical and organizational measures that were not adequate to ensure, from the design stage, and to be able to demonstrate, that the processing is carried out in accordance with the Regulation;
- b) Articles 24 and 28 of the Regulation, also in relation to Article 2 – fourteenth of the Code, for having carried out personal data processing using internal and external subjects within the company organization, in violation of the obligations imposed on the data controller regarding the identification, training, direction, and monitoring of the designated subjects;
- c) Articles 12 and 15-22 of the Regulation for the failure to implement company procedures and measures suitable to ensure the adequate and timely response to requests for the exercise of rights by the data subjects.

2. THE DEFENSE OF THE CONTROLLER

The party did not avail itself of the right to be heard by the Authority but submitted its defensive memoranda and documentation pursuant to Article 166, paragraph 6 of the Code and Article 13 of internal regulation no. 1/2019 (see Prot. no. 107276 of September 12, 2024).

In the aforementioned defensive memorandum, first of all with reference to complaint no. 352614, E.ON has indicated the measures implemented to improve the level of corporate compliance in managing digital campaigns. More specifically, based on the new system "those who fill out the online form requesting to be contacted for receiving information about the E.ON product/service will receive an email through which they can confirm their data and the will expressed online." The numbers will also be subjected to

verification by the RPO before contact and in any case "before the collection of data, through the online form, a specific information notice will be provided regarding this processing activity and the flow described above (filling out the online form, sending confirmation emails and data confirmation and contact willingness, E.ON telephone contact), with the data subjects always retaining the right to revoke the interest expressed and confirmed, according to the procedure mentioned above, before the actual contact by E.ON, being able to use the channels for the exercise of rights made available by the Company."

Regarding complaint no. 367993, E.ON has disputed the telephone contacts subject to complaint, reiterating that it did not communicate to third parties the complainant's data and specifying, however, that it had contacted her "for two purposes: a first call (successful) was made to formalize the contracts, while the other telephone contact attempts occurred between early January and early February to carry out the so-called 'caring call for the first bill.' In fact, not having reached the Customer on the first attempt, as provided by procedure, three other attempts were made, all recorded with a negative outcome ("no answer" or "failed," attachment 1) when, moreover, Mrs. XX had not revoked her consent to E.ON's marketing activities validly expressed (both in the electricity contract and in the gas supply contract – see attachments 2 of the reply notes of June 14, 2024 to note Prot. no. 64362) and correctly recorded in E.ON's systems."

On the same occasion, the Company also specified that "this type of so-called 'caring' call is exclusively aimed at obtaining a confirmation that the requested services are in line with the Customer's expectations, both from an economic point of view and in terms of clarity of the information provided during the activation and subscription phase. In the case of a negative outcome of the 'caring' call, the contact is recorded as 'unreachable' (...) and excluded from subsequent telephone contacts."

The Company has also noted that the circumstance declared by the interested party, regarding the fact that the calls subject to complaint were aimed at the marketing of water purifiers, which are not marketed by the Company, served to demonstrate that the contacts in question could not be attributed to E.ON (see the email dated April 29, 2024, attached to the complaint).

Regarding the communications transmitted by E.ON, the Company observed that during the activation phase of the services, the complainant had provided valid consent for the processing of personal data for marketing purposes that could be carried out through ordinary letters and/or telephone calls, emails, SMS, MMS, notifications, and newsletters.

E.ON also highlighted that "according to E.ON's technical and organizational measures, the personal data of E.ON customers are not accessible to unauthorized third parties; there are no integrations and

automations that allow 'open' access to the database (CRM) to external systems of the Company and for the sharing of personal data with third parties for marketing purposes; there are no unauthorized or unlawful accesses to E.ON's IT systems containing personal data of its customers, including those of the complainant."

On this point, the Company noted that the phenomenon of suspicious calls is attributable to third parties outside the corporate organization who act illegally, highlighting the commitment made in the fight against this phenomenon and in raising user awareness.

With reference to the methods of loading contracts onto the corporate systems, E.ON pointed out that although the services in favor of the complainant were activated through the traditional management flow and thus with the involvement of personnel appointed by the Company, currently "a digitalization activity of the user acquisition processes is underway through the use of tablets and dedicated apps, which allow the user to directly record their wishes on E.ON's IT systems."

Furthermore, in order to "ensure and enhance the quality of the acquisition phase of commercial activities across various sales channels, the establishment of the Acquisition Quality Committee is also included, which, among its main activities, deals with: (i) monitoring and controlling the implementation of resolutions and measures of the competent authorities regarding contracts/services/unrequested activations; (ii) checking and verifying the effectiveness of the operational procedures implemented to meet the aforementioned resolutions and measures adopted by the Company; (iii) making communications (such as reports, warnings, etc.) to channels, vendors, trade associations, regulatory bodies, and other interested parties regarding issues related to acquisition processes; (iv) cooperating with various corporate departments to ensure that the corporate procedures for the correct processing of personal data are implemented."

In addition, regarding the complaints mentioned in complaint no. 367993, E.ON reiterated that the unwanted contacts are attributable to the conduct of third parties outside the corporate structure and that it cannot be ruled out that the complainant's data may be in the possession of other data controllers, given that the public role held in the past by the complainant "may have led her to provide her personal data to various parties over the more than twenty years since she has had the number."

Finally, the Company represented the efforts made to prevent human errors also "through the provision of training courses, the assignment of specific privacy authorization tasks for corporate personnel, the issuance of specific instructions, the use of tablets and apps."

Regarding the measures adopted in implementation of the so-called accountability principle, the Company stated that it has adopted the following precautions: "- a data protection management system ("DPMS"), subject to constant updating, which includes, among others, guidelines and procedures for managing requests from data subjects and managing data breaches, information pursuant to Articles 13 and 14 of the Regulation, tools (such as the Assessment of Data Protection Risks for risk assessment activities under the Regulation); - the appointment of a DPO for the Italian E.ON companies, who collaborates and works in coordination with other oversight bodies identified (including the Cyber Security Manager); - the identification of internal figures with specific tasks and delegations regarding privacy, including data privacy coordinators (some corporate managers who are more involved in privacy issues), and data protection experts who operate in close coordination with the relevant IT figures and the Information Security Officer; - procedures, processes, and checklists for the accreditation of third parties (e.g., cybersecurity checklist, procurement process, attachment 5); - templates for contracts for the processing of personal data for managing privacy relationships with parties qualifying as data processors that contain the elements pursuant to Article 28 of the Regulation and indications on the technical and organizational measures guaranteed by the processor (attachment 6); - authorizations with instructions regarding the protection of personal data for E.ON personnel during the hiring phase (attachment 7); - the adoption of a package of guidelines (so-called People Guidelines) that indicate how to act in various situations, including Data Protection guidelines (attachment 8) and Information Security guidelines (attachment 8bis) which are in fact instructions for corporate personnel; - authorizations for those who fall under the role of system administrators

(attachment 9); - procedures."

****Privacy Training for Company Personnel;****

- ****Records of Data Processing Activities;****

- ****Internal Audits on the Correct Application of Procedures and the GDPR in Internal Processes.****

E.ON then contested the unfounded nature, generality, and lack of evidence regarding the alleged violation of Article 2 -quaterdecies of the Code, reiterating that the Company organizes periodic training sessions, both in-person and remotely, aimed at employees and the sales network. More specifically, the Company stated that corporate policies require personnel to undergo privacy training courses "at the time of hiring (provided through an e-learning platform) and during the employment relationship, (typically the second training occurs after the first quarter) ad hoc training sessions are organized by the Legal & Compliance Department of E.ON Italia S.p.a. (during which privacy roles, legal bases for processing, validity requirements for consents, applicable principles for processing activities, etc. are discussed). Other dedicated training sessions are organized with recurring monthly meetings with personnel from offices and departments that primarily engage in personal data processing activities, such as those dealing with sales and customer care, with whom further information and instructions are shared (for example, regarding the privacy notices to be used, the consents to be valued in corporate systems, the management of requests from data subjects). The training material is always accessible on the company intranet where policies, procedures, notices, guidelines, and other elements that are part of the so-called Data Protection Management System are available."

Additionally, personnel receive a specific designation, which also includes instructions regarding the processing of personal data, and corporate policies are always accessible from the intranet. Each collaborator, moreover, receives a personalized authorization profile based on the tasks performed.

In relation to the contested violation of Article 28 of the Regulation, E.ON noted that it has adopted the following measures:

- ****Supplier Accreditation Procedure;****

- ****Use of Cybersecurity Checklists for audits pursuant to Articles 24, 25, 28, and 32 of the GDPR submitted to suppliers during engagement and throughout the relationship;****

- ****Verification of service contracts with its suppliers also focusing on privacy, needing to ascertain whether or not to conclude a data processing agreement, as well as correctly defining privacy roles between the parties and adequate audit clauses;****

- ****Use of a model contract for the processing of personal data, which contains specific instructions regarding the technical and organizational measures that the data processor must ensure;****

- ****Training of personnel also on the contracting process that requires acceptance of the DPA, along with the associated security measures, prior to the contracting of the partner.****

The Company also stated that it monitors the actions of external processors even during the relationship, for example, by updating agreements concluded pursuant to Article 28 of the Regulation and submitting new and/or additional checklists.

With specific reference to supplier XX, the data controller clarified that it was positively evaluated based on the certifications and accreditations held. E.ON did not consider it appropriate to take punitive actions against this Processor since "following further internal checks after the submission of the reply notes on June 14, it was established that the lack of response to Ms. XX's request must be attributed to a material error by E.ON personnel and not the external supplier. More specifically, it was confirmed that the registered letter exercising the rights was not delivered to the Customer Care office, responsible for managing complaints from data subjects, but to a different department that was unable to index and timely direct the request as the registered letter had a generic recipient." In this regard, the Company highlighted that it was an isolated case due to an error that could not be avoided, despite the application of technical and organizational measures by the Company.

Similarly, the lack of response to the request for the exercise of rights pursuant to Articles 15 et seq. of the Regulation (see complaint no. 352614) - regarding which the Company reiterated that the data

subject had received information and clarifications also during the telephone conversation with Customer Care - based on the data controller's thesis must be attributed "to human error in the process followed for managing paper mail. However, unlike what was already reported in the reply notes of June 14, 2024, it is specified that the mistake was made by E.ON personnel and not by supplier XX." The Company clarified on this point that the case should be assessed as an exceptional event, which can occur despite the diligence employed and the adoption of the following compliance measures:

- 1) **Implementation of various channels to allow data subjects to easily exercise their rights;**
- 2) **Designation of a data protection officer and assignment of specific privacy roles/tasks to E.ON personnel (the so-called data privacy coordinators);**
- 3) **Identification of individuals responsible for managing requests from data subjects (all privacy complaints are handled by a dedicated team);**
- 4) **Providing periodic and specific instructions to**

personal data, through privacy authorizations, training courses, meetings, guidelines, etc., 4) the establishment of a dedicated procedure for managing requests from data subjects, which is part of the Data Protection Management System of E.ON available to company personnel, 5) the implementation of a company procedure for managing physical mail."

In conclusion, the Company also expressed the intention to "integrate the company procedure for managing physical mail; - conduct further training sessions with company personnel to reiterate the importance of properly valuing the privacy wishes of data subjects and the necessity of following company procedures; - continue with the digitization process through the use of tablets, apps, and dedicated portals and overcome analog procedures during which material errors by company personnel may occur."

3. ASSESSMENTS OF THE AUTHORITY

It should first be noted that the allegations and documentation provided by the Company during the proceedings before the Authority did not allow for overcoming the concerns raised by the Office, nor do they allow for considering the burden of proving the implementation of adequate compliance measures with respect to personal data protection provisions, which rests on the data controller pursuant to the combined provisions of Articles 5, paragraph 2, and 24 of the Regulation (on this point, see Recital No. 74 of the Regulation, which states that "It is appropriate to establish the general responsibility of the data controller for any processing of personal data that it has carried out directly or that others have carried out on its behalf. In particular, the data controller should be required to implement appropriate and effective measures and be able to demonstrate compliance of processing activities with this Regulation, including the effectiveness of the measures. Such measures should take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons").

While it is true that, in line with its European origins, the regulation on personal data protection, with some exceptions, does not impose particular formalities, it is equally clear that the data controller must bear the burden of being constantly able to demonstrate compliance with the applicable regulations.

On this point, the Authority is aware of the difficulties inherent in the absence of formal indicators - for example, as imposed by national civil law when it regulates the essential elements of a legal transaction or the written form *ad substantiam* - which effectively creates a particularly rigorous obligation on the part of the controller regarding the choice of methods and timing of compliance. However, the absence of particular formalities, while generating greater accountability for the data controller, also guarantees a wide freedom of action and choice.

A logical corollary of this complex reconstruction is that there cannot be a universal formula regarding the correct fulfillment of such obligations and burdens, and that consequently, a case-by-case evaluation must be conducted, taking into account the socio-economic context, the corporate structure, as well as the risks to the rights and freedoms of data subjects.

In this specific case, such a premise appears necessary considering the circumstance that from the

examination of the defensive acts and the documentation provided by E.ON, it emerges that there is not a complete assimilation of the rationale and scope of such obligations.

The circumstances in the proceedings, in fact, while presenting a picture of a corporate organization sensitive to the matter, which, as will be discussed more extensively below, has implemented a series of measures and is still called to implement others, have also highlighted that the controller has provided statements that were partially retracted, as well as produced incomplete and unfilled forms, most of which lack temporal references.

Such behavior does not suffice to fulfill the burden of demonstrating that the measures and actions for implementing the regulation, although theoretically provided for in part, have actually been put in place and are subject to periodic control and updating.

On the merits, with reference to both complaints, the violation of Articles 5, 6, 7, and 24 of the Regulation, as well as Article 130 of the Code, is fully confirmed, for having carried out telemarketing activities in violation of the principles of lawfulness and accountability, in the absence of an adequate legal basis and implementing technical and organizational measures that are not sufficient to ensure, from the design stage, and to be able to demonstrate, that the processing is carried out in accordance with the Regulation.

In fact, regarding the so-called digital promotional campaigns, the processing of personal data collected through online forms cannot be considered legitimate in the absence of the implementation of measures suitable for verifying the source and identity of the subject providing the information. This flaw, inherent in the original data collection, inevitably has repercussions on the subsequent processing operations carried out on the same personal data.

It should also be noted that in the absence of the aforementioned measures, such types of online forms could be surreptitiously exploited to make outbound contacts under the guise of requests for follow-up from the data subject.

In other words, the provision of personal data illicitly obtained or "not consented" within online forms would ultimately give an appearance of legality regarding the processing of personal data and contact lists of illicit origin, effectively realizing an inadmissible laundering of personal data and fueling the underground market of telemarketing. Moreover, considering the pervasive use of this type of form and social platforms, the interested parties reached by unwanted promotional contacts made in the interest of E.ON, as occurred in the case of the current complainant, could have been very numerous. In this regard, while understanding the economic and temporal costs that the implementation of such measures entails - which the Company has also mentioned - it is represented that these precautions not only constitute the result of the necessary balance between business freedom and the right to privacy, but also prove useful for the data controller, as they allow for the preservation of the legality and accuracy of the data, as well as for conducting re-contact campaigns only towards users who are actually interested in the proposed services.

Similarly, the circumstances that emerged regarding the re-contact methods subject to complaint no. 367993 confirm the existence of the violations contested in relation to Articles 5, 6, 7, and 24 of the Regulation, as well as Article 130 of the Code, since they revealed on one hand the unclear management of the processes for collecting consent for marketing purposes and loading contracts onto corporate systems, and on the other hand, the observations provided highlighted a not fully comprehensive assimilation of the regulations concerning so-called customer caring contacts. In this regard, E.ON specified that the so-called customer caring campaigns are aimed exclusively at obtaining confirmation that the requested services meet the customer's expectations. However, aside from the observation that the insistence and frequency of contacts suggest a secondary commercial purpose, even these types of contact, regardless of the medium used (phone, email, SMS), must be carried out while preserving the right of opposition of the interested party and, above all, must be contained within reasonable temporal limits and attempts. In the absence of such precautions, the conduct of such re-contact campaigns results in an inadmissible invasion of the customer's personal sphere.

In the case of complaint no. 367993, however, by the Company's own admission, four contact attempts were made against the interested party over the course of two weeks and just under twenty communications (emails and SMS) in the four months following activation. The responses provided by the Company also confirm the occurrence of violations of the obligations incumbent on the data controller regarding the actions of those who process personal data on behalf of E.ON, as interpreted in light of the more general principle of accountability. In this regard, it is first noted that the retraction made during the proceedings - regarding the subject to whom the alleged human error that caused the contested violations should be attributed - indicates, in itself, a lack of complete mastery of the business flows and the treatments carried out. A correct management of the processing chain, in fact, presupposes that the data controller can effectively and easily reconstruct roles and responsibilities, especially in cases where the investigation pertains to the physiological and ordinary management of customers and so-called prospects.

Furthermore, regarding the fulfillment of the obligations incumbent on the data controller pursuant to Article 28 of the Regulation (so-called *culpa in eligendo* and *culpa in vigilando*), both with reference to XX and to the more general practice of selecting and monitoring suppliers, the investigation carried out reveals, on one hand, the omission of measures aimed at ensuring the selection of partners that provide sufficient guarantees to implement adequate technical and organizational measures so that the processing meets the requirements of the Regulation and guarantees the protection of the rights of the interested party, and on the other hand, the lack of control and supervision over the personal data processing activities carried out by such subjects on behalf of the Company. In fact, regarding the process of selecting and contracting suppliers, E.ON limited itself to providing a brief management scheme, lacking a date and corporate references, and a model for appointing a data processing manager, the last update of which dates back two years ago. Similarly, regarding the monitoring of suppliers' actions, the Company merely referred to the use of checklists. However, such allegations and documents, in fact, indicate a tendency towards merely formal compliance with such obligations, not accompanied by a sufficiently performing and structured process, which allows *ex ante* to arrive at the selection of suppliers who possess adequate competencies in privacy matters and *ex post* to carry out supervision and monitoring of their actions.

The events subject to complaint and the responses provided by the Company, on the other hand, confirm the occurrence of non-compliance with the obligations related to the appointment, direction, and training of the subjects operating within the organization of the data controller carrying out personal data processing.

Based on the thesis presented by the Company, such episodes should be attributed to alleged human errors, which occurred despite the implementation of technical and organizational measures such as internal training on privacy and the provision of documented instructions. However, the absence of any documentary evidence to prove the actual conduct of such training, along with the provision of generic and dated instructions, when evaluated in the context of the admitted mismanagement of both episodes subject to complaint, serves to demonstrate the violation of the provisions imposed by Article 2-quaterdecies of the Code, as interpreted also in relation to Article 5 of the Regulation.

In this regard, it is noted that, regardless of the fact that the data controller provided only a set of instructions lacking elements to prove their actual use, the document in question contains dated references (i.e., references to sensitive data and the figure of the data processor) and, above all, lacks any personalization and/or distinction with respect to the specific tasks performed, the categories of data processed, and the specific risks to the rights and freedoms of the data subjects.

For the reasons just stated, it must also be considered that there has been a violation of Articles 12 and 15-22 of the Regulation, as the human error invoked by the Company cannot have any exonerating effect. Furthermore, the exception raised by E.ON regarding the circumstance that the data subject had nonetheless obtained a telephone clarification regarding the methods of collecting her personal data cannot be accepted. The complainant's request submitted pursuant to Articles 15 et seq. of the Regulation was, in fact, submitted at a later time than the telephone clarification provided by Customer Care and was aimed at obtaining more specific and detailed information.

It follows that the data controller was required to provide the requested feedback in the manner and within the timeframes set out in Article 12 of the Regulation, and the exception regarding manifestly unfounded or excessive requests cannot apply for the reasons just illustrated. Moreover, pursuant to Article 15 of internal regulation no. 1/2019, complaints regarding rights must be accompanied by the requests previously addressed to the data controller and any responses received, such that this obligation in the case at hand constituted a requirement for the admissibility of the complaint.

In conclusion, E.ON's liability for all the contested violations must be definitively confirmed.

4. CONCLUSIONS

For the reasons stated above, E.ON's liability for the following violations is deemed established:

- Articles 5, 6, 7, and 24 of the Regulation, as well as Article 130 of the Code, for having processed personal data in violation of the principles of lawfulness and accountability, in the absence of an appropriate legal basis and implementing technical and organizational measures that are inadequate to ensure, from the design stage, and to be able to demonstrate, that the processing is carried out in accordance with the Regulation;
- Articles 24 and 28 of the Regulation, also in relation to Article 2-quaterdecies of the Code, for having processed personal data using internal and external subjects to the corporate organization, in violation of the obligations imposed on the data controller regarding the identification, training, direction, and monitoring of the actions of the designated subjects;
- Articles 12 and 15 to 22 of the Regulation for the failure to implement corporate procedures and measures suitable to ensure adequate and timely feedback to requests for the exercise of rights by data subjects.

Having also established the unlawfulness of the Company's conduct concerning the treatments examined, it is necessary to:

- impose on E.ON, pursuant to Article 58, paragraph 2, letter f) of the Regulation, a prohibition on any further processing of the personal data of the complainants;
- order E.ON, pursuant to Article 58, paragraph 2, letter d) of the Regulation, to update the forms necessary to authorize the processing of personal data for individuals operating under its direct authority, pursuant to Article 2-quaterdecies;
- adopt an injunction order, pursuant to Articles 166, paragraph 7, of the Code and 18 of Law no. 689/1981, for the application against E.ON of the administrative pecuniary sanction provided for by Article 83, paragraphs 3 and 5, of the Regulation.

5. INJUNCTION ORDER FOR THE APPLICATION OF THE ADMINISTRATIVE PECUNIARY SANCTION

The violations indicated above necessitate the adoption of an injunction order, pursuant to Articles 166, paragraph 7, of the Code and 18 of Law no. 689/1981, for the application against E.ON of the administrative pecuniary sanction provided for by Article 83, paragraphs 3 and 5, of the Regulation (payment of an amount up to €20,000,000.00 or, for companies, up to 4% of the global annual turnover of the previous financial year, if higher).

For the determination of the maximum applicable pecuniary sanction, it is therefore necessary to refer to E.ON's turnover, as derived from the latest available financial statement (December 2023) in accordance with previous measures adopted by the Authority, and thus this maximum applicable amount is determined, in this case, at €89,273,777.20.

For the determination of the amount of the sanction, it is necessary to take into account the elements indicated.

in Article 83, paragraph 2, of the Regulation;

In the case at hand, the following are relevant:

- 1) as an aggravating factor, pursuant to Article 83, paragraph 2, letter a) of the Regulation, the seriousness of the violations, taking into account the subject matter and purposes of the processed data, related to the overall phenomenon of telemarketing, regarding which the Authority has adopted, particularly in the last five years, numerous measures that have thoroughly examined the multiple

elements of criticality, providing the data controllers with numerous indications to adapt their processing to the current regulations and to mitigate the impact of nuisance calls on the data subjects; 2) as a mitigating factor, pursuant to Article 83, paragraph 2, letter a) of the Regulation, the degree of cooperation with the supervisory Authority, also due to the commitment made in order to improve, already during the proceedings, the corporate compliance in relation to the regulations on the protection of personal data.

Based on the complex of the aforementioned elements and the principles of effectiveness, proportionality, and deterrence provided for in Article 83, paragraph 1, of the Regulation, and taking into account the necessary balancing between the rights of the data subjects and the freedom of enterprise, also in order to limit the economic impact of the sanction on the organizational and functional needs of the Company, it is deemed appropriate to apply to E.ON the administrative sanction of payment of an amount of €892,738.00, equal to 0.04% of the turnover and 1% of the maximum administrative fine.

In this case, it is considered that the accessory sanction of publication on the website of the Authority of this measure, provided for in Article 166, paragraph 7 of the Code and Article 16 of the Regulation of the Authority No. 1/2019, should be applied, taking into account the nature of the processing and the conduct of the Company, as well as the risk elements for the rights and freedoms of the data subjects. In implementation of the principles of Article 83 of the Regulation, the imposition of this accessory sanction appears reasonable and proportionate in relation to the seriousness and particular disvalue of the conduct subject to censure, especially considering the criticalities found in relation to the realization of the so-called digital campaigns.

On this point, the peculiar seriousness inherent in the use of re-contact forms to give an appearance of legality to unlawfully acquired personal data is highlighted, and it is also attributable to the vast number of interested parties involved, due to the rampant and pervasive use of social platforms.

Finally, the prerequisites of Article 17 of Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority, are met.

ALL OF THE ABOVE, THE AUTHORITY

- a) imposes on E.ON, pursuant to Article 58, paragraph 2, letter f) of the Regulation, the prohibition of any further processing of the personal data of the complainants;
- b) orders E.ON, pursuant to Article 58, paragraph 2, letter d) of the Regulation, to update the forms useful for authorizing the processing of personal data of persons operating under its direct authority, pursuant to Article 2-quaterdecies;
- c) orders E.ON, pursuant to Article 157 of the Code, to communicate to the Authority, within thirty days from the notification of this measure, the initiatives undertaken in order to implement the imposed measures; any failure to comply with the provisions of this point may result in the application of the administrative pecuniary sanction provided for in Article 83, paragraph 5, of the Regulation.

ORDERS

E.ON Energia S.p.A., represented by the legal representative pro tempore, with registered office in Milan (MI), Via dell'Unione No. 1, VAT No. 03429130234, to pay the sum of €892,738.00 (eight hundred ninety-two thousand seven hundred thirty-eight/00) as an administrative pecuniary sanction for the violations indicated in the reasoning, stating that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by complying with the imposed prescriptions and paying, within thirty days, an amount equal to half of the imposed sanction.

ORDERS

the aforementioned Company, in case of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €892,738.00 (eight hundred ninety-two thousand seven hundred thirty-eight/00), according to the methods indicated in the annex, within 30 days from the notification of this measure, under penalty of the adoption of the consequent executive acts pursuant to Article 27 of Law No. 689/1981.

DIRECTS

- a) the publication of this measure, pursuant to Articles 154-bis of the Code and 37 of Regulation No.

1/2019, as well as the application of the accessory sanction of publication on the website of the Authority of this injunction order, as provided for in Articles 166, paragraph 7 of the Code and 16 of Regulation of the Authority No. 1/2019;

b) the annotation of this measure in the internal register of the Authority - provided for in Article 57, paragraph 1, letter u), of the Regulation, as well as in Article 17 of Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Authority - relating to the violations and the measures adopted in accordance with Article 58, paragraph 2, of the Regulation itself.

Pursuant to Article 78 of the Regulation, as well as Articles 152 of the Code and 10 of Legislative Decree No. 150 of September 1, 2011, an appeal against this provision may be submitted to the ordinary judicial authority, with a petition filed at the ordinary court of the place where the data controller resides, or, alternatively, at the court of the place of residence of the data subject, within thirty days from the date of communication of the provision itself, or within sixty days if the appellant resides abroad.

Rome, November 27, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Scorza

THE SECRETARY GENERAL

Mattei